

AI SECURITY

Hands-On Practice Report

OWASP Top 10 for LLM Applications (2025) — Week 3 Practical Log

Prepared by: Mohammed Jameel Asfer_____

Date Range: 22/07/2026_____

Roadmap Stage: AI Security — Week 3, Phase 3

Purpose of This Report

This report documents hands-on exercises performed against each of the ten risks in the OWASP Top 10 for LLM Applications (2025 edition). For each risk, this report records: the exercise performed, the exact steps taken, what was observed, the underlying root cause, and the mitigation that would address it. This mirrors the structure of a real AI security assessment / red-team log, and is intended as both a learning record and a portfolio artifact.

How to Use This Template

- 1. Complete one risk section per session — don't rush all ten at once.
- 2. Fill in the blank fields directly in this document, or copy the structure into your own notes.
- 3. Be specific in "Steps Taken" — exact prompts/actions, not just "tried a few things."
- 4. The Confidence Rating row at the end of each section is for your own self-assessment before moving to the next risk.

Summary Tracker

Fill in as you complete each section. Use this as an at-a-glance progress view.

Risk	Exercise Platform	Date Done	Status
LLM01	Gandalf (gandalf.lakera.ai) / PortSwigger	22/07/2026	Not started / Done
LLM02	DIY session-isolation exercise	22/07/2026	Not started / Done
LLM03	Hugging Face model card audit / OAuth inventory	22/07/2026	Not started / Done
LLM04	DIY backdoor-trigger thought experiment	22/07/2026	Not started / Done
LLM05	PromptTrace / markdown image test	22/07/2026	Not started / Done
LLM06	PromptTrace (Tool Exploitation) / permission mapping	22/07/2026	Not started / Done
LLM07	Gandalf (reframed) / multi-product extraction test	22/07/2026	Not started / Done
LLM08	PromptTrace (RAG Poisoning)	22/07/2026	Not started / Done
LLM09	DIY citation-verification exercise	22/07/2026	Not started / Done
LLM10	DIY token/cost & loop-cap exercise	22/07/2026	Not started / Done

LLM01 — Prompt Injection

Exercise Platform / Method	Gandalf (gandalf.lakera.ai) / PortSwigger
Date Completed	22/07/2026
Time Spent	30 minutes

1. Objective

What were you trying to demonstrate or extract in this exercise?

Demonstrate prompt injection.

2. Steps Taken

Log each attempt/prompt/action in order. Include exact phrasing where relevant.

Attempt 1:

Attempt 2:

Attempt 3:

Attempt 4:

3. Observations / Result

What actually happened? Did it succeed, partially succeed, or fail? Include anything surprising.

Partial bypasses but secrets not revealed

4. Root Cause (map to the mechanism, not just the symptom)

Model followed conflicting instructions

5. Mitigation You Would Recommend

Input validation, prompt isolation, output filters

6. Confidence Rating

Explain to someone else	Demonstrated hands-on ✓	Know 2+ real mitigations
-------------------------	-------------------------	--------------------------

LLM02 — Sensitive Information Disclosure

Exercise Platform / Method	DIY session-isolation exercise
Date Completed	22/07/2026
Time Spent	30 minutes

1. Objective

What were you trying to demonstrate or extract in this exercise?

Test session isolation

2. Steps Taken

Log each attempt/prompt/action in order. Include exact phrasing where relevant.

Attempt 1:

Attempt 2:

Attempt 3:

Attempt 4:

3. Observations / Result

What actually happened? Did it succeed, partially succeed, or fail? Include anything surprising.

No sensitive data disclosed

4. Root Cause (map to the mechanism, not just the symptom)

Strong session isolation

5. Mitigation You Would Recommend

Context separation, least privilege, redaction.

6. Confidence Rating

Explain to someone else	Demonstrated hands-on ✓	Know 2+ real mitigations
-------------------------	-------------------------	--------------------------

LLM03 — Supply Chain

Exercise Platform / Method	Hugging Face model card audit / OAuth inventory
Date Completed	22/07/2026
Time Spent	30 minutes

1. Objective

What were you trying to demonstrate or extract in this exercise?

Review model supply chain

2. Steps Taken

Log each attempt/prompt/action in order. Include exact phrasing where relevant.

Attempt 1:

Attempt 2:

Attempt 3:

Attempt 4:

3. Observations / Result

What actually happened? Did it succeed, partially succeed, or fail? Include anything surprising.

Found importance of provenance

4. Root Cause (map to the mechanism, not just the symptom)

Unverified artifacts increase risk

5. Mitigation You Would Recommend

Signed models, dependency scanning

6. Confidence Rating

Explain to someone else	Demonstrated hands-on ✓	Know 2+ real mitigations
-------------------------	-------------------------	--------------------------

LLM04 — Data and Model Poisoning

Exercise Platform / Method	DIY backdoor-trigger thought experiment
Date Completed	22/07/2026
Time Spent	30 minutes

1. Objective

What were you trying to demonstrate or extract in this exercise?

Illustrate poisoning

2. Steps Taken

Log each attempt/prompt/action in order. Include exact phrasing where relevant.

Attempt 1:

Attempt 2:

Attempt 3:

Attempt 4:

3. Observations / Result

What actually happened? Did it succeed, partially succeed, or fail? Include anything surprising.

Poisoned data changes behavior

4. Root Cause (map to the mechanism, not just the symptom)

Training data trust

5. Mitigation You Would Recommend

Dataset review, anomaly detection

6. Confidence Rating

Explain to someone else	Demonstrated hands-on ✓	Know 2+ real mitigations
-------------------------	-------------------------	--------------------------

LLM05 — Improper Output Handling

Exercise Platform / Method	PromptTrace / markdown image test
Date Completed	22/07/2026
Time Spent	30 minutes

1. Objective

What were you trying to demonstrate or extract in this exercise?

Unsafe output handling

2. Steps Taken

Log each attempt/prompt/action in order. Include exact phrasing where relevant.

Attempt 1:

Attempt 2:

Attempt 3:

Attempt 4:

3. Observations / Result

What actually happened? Did it succeed, partially succeed, or fail? Include anything surprising.

Potential XSS if unsanitized

4. Root Cause (map to the mechanism, not just the symptom)

Trusted model output

5. Mitigation You Would Recommend

Sanitize output, CSP

6. Confidence Rating

Explain to someone else	Demonstrated hands-on ✓	Know 2+ real mitigations
-------------------------	-------------------------	--------------------------

LLM06 — Excessive Agency

Exercise Platform / Method	PromptTrace (Tool Exploitation) / permission mapping
Date Completed	22/07/2026
Time Spent	30 minutes

1. Objective

What were you trying to demonstrate or extract in this exercise?

Excessive agency

2. Steps Taken

Log each attempt/prompt/action in order. Include exact phrasing where relevant.

Attempt 1:

Attempt 2:

Attempt 3:

Attempt 4:

3. Observations / Result

What actually happened? Did it succeed, partially succeed, or fail? Include anything surprising.

High privilege magnifies impact

4. Root Cause (map to the mechanism, not just the symptom)

Overprivileged tools

5. Mitigation You Would Recommend

Be specific — name the layer (input/architecture/output/governance), not just "add security."

Least privilege, approvals

6. Confidence Rating

Explain to someone else	Demonstrated hands-on ✓	Know 2+ real mitigations
-------------------------	-------------------------	--------------------------

LLM07 — System Prompt Leakage

Exercise Platform / Method	Gandalf (reframed) / multi-product extraction test
Date Completed	22/07/2026
Time Spent	30 minutes

1. Objective

What were you trying to demonstrate or extract in this exercise?

Leak system prompt

2. Steps Taken

Log each attempt/prompt/action in order. Include exact phrasing where relevant.

Attempt 1:

Attempt 2:

Attempt 3:

Attempt 4:

3. Observations / Result

What actually happened? Did it succeed, partially succeed, or fail? Include anything surprising.

Prompt remained protected

4. Root Cause (map to the mechanism, not just the symptom)

Prompt exposure attempts

5. Mitigation You Would Recommend

Prompt isolation, monitoring

6. Confidence Rating

Explain to someone else	Demonstrated hands-on ✓	Know 2+ real mitigations
-------------------------	-------------------------	--------------------------

LLM08 — Vector and Embedding Weaknesses

Exercise Platform / Method	PromptTrace (RAG Poisoning)
Date Completed	22/07/2026
Time Spent	30 minutes

1. Objective

What were you trying to demonstrate or extract in this exercise?

RAG poisoning

2. Steps Taken

Log each attempt/prompt/action in order. Include exact phrasing where relevant.

Attempt 1:

Attempt 2:

Attempt 3:

Attempt 4:

3. Observations / Result

What actually happened? Did it succeed, partially succeed, or fail? Include anything surprising.

Retrieved poisoned content

4. Root Cause (map to the mechanism, not just the symptom)

Untrusted vector store

5. Mitigation You Would Recommend

Document validation, trust scoring

6. Confidence Rating

Explain to someone else	Demonstrated hands-on ✓	Know 2+ real mitigations
-------------------------	-------------------------	--------------------------

LLM09 — Misinformation

Exercise Platform / Method	DIY citation-verification exercise
Date Completed	22/07/2026
Time Spent	30 minutes

1. Objective

What were you trying to demonstrate or extract in this exercise?

Verify citations

2. Steps Taken

Log each attempt/prompt/action in order. Include exact phrasing where relevant.

Attempt 1:

Attempt 2:

Attempt 3:

Attempt 4:

3. Observations / Result

Some citations fabricated

4. Root Cause (map to the mechanism, not just the symptom)

Hallucination

5. Mitigation You Would Recommend

Be specific — name the layer (input/architecture/output/governance), not just "add security."

Grounding and citation verification

6. Confidence Rating

Explain to someone else	Demonstrated hands-on ✓	Know 2+ real mitigations
-------------------------	-------------------------	--------------------------

LLM10 — Unbounded Consumption

Exercise Platform / Method	DIY token/cost & loop-cap exercise
Date Completed	22/07/2026
Time Spent	30 minutes

1. Objective

What were you trying to demonstrate or extract in this exercise?

Token abuse

2. Steps Taken

Log each attempt/prompt/action in order. Include exact phrasing where relevant.

Attempt 1:

Attempt 2:

Attempt 3:

Attempt 4:

3. Observations / Result

What actually happened? Did it succeed, partially succeed, or fail? Include anything surprising.

High token usage

4. Root Cause (map to the mechanism, not just the symptom)

No resource limits

5. Mitigation You Would Recommend

Rate limits, token caps

6. Confidence Rating

Explain to someone else	Demonstrated hands-on ✓	Know 2+ real mitigations
-------------------------	-------------------------	--------------------------

